AI for Good Sandbox Hackathon – Miqyas – Policy Desk: policy-grounded UAE health agents

Team leader: Sumit Uttamchandani (Miqyas, pre-incorporation)
Team members: Solo entry. Contact: Sumit Uttamchandani, sumitu@gmail.com
Github link: https://github.com/SumitU1/miqyas-itu-hackathon

1. Introduction

People in the UAE now keep lab results, wearable streams and coach conversations in apps that are not hospitals. The rules that touch such an app sit in different texts from different authorities: health-sector law written for facilities, a general data-protection law, emirate-level AI policies, advertising rules and non-binding AI guidance. Miqyas is a lifelong health record and coach for people in the UAE. For this hackathon we built a small, separate agentic layer around it. It has a **knowledge base** of 23 public UAE and ITU documents (689 chunks, with a citation on every chunk), a **Policy and Legal Adviser** agent, three institutional agents (the Miqyas Coach, a Partner Clinic and a Health-Data Authority) with different mandates and different information, and a **Coordinator** that plays the Y.3172 machine learning function orchestrator (MLFO). Every message, knowledge-base query, model call and decision is written to a hash-chained audit log, and each decision can be replayed back to the passage, page and link that grounded it.

This report maps the solution to ITU-T Y.3172 and to the AI Readiness Framework (Report 2.0), links each pipeline node to the UAE documents we hold, runs four sequenced error scenarios, and lists policy and standards gaps. As the brief asks, gaps are stated at domain level (consumer health AI), each with a global example. **Scope and honesty:** members and scenarios are synthetic, documents are public, nothing is legal or medical advice, and no lawyer or clinician has reviewed the knowledge base, the scenarios or any answer. Gap statements are worded as "the text says", not as findings of law.

2. Description of the use case

The problem. A member uploads a lab report, links a wearable and chats with an AI coach. Later a partner clinic asks for records, a regulator asks where the data went, and marketing wants to describe what the coach can do. Each question is answered by a different document in a different authority's voice, and for a consumer app some of those documents disagree or say nothing. Existing options are chatbots that answer without showing a source, or policy PDFs that no system can check an action against. Neither leaves a record a reviewer can replay.

The solution. We make the rules part of the runtime. (1) The knowledge base keeps article and page for every chunk and retrieves with an evidence gate (strong, weak or none). (2) The Adviser answers only on strong evidence (top score at least 15 and query coverage at least 0.70); otherwise it abstains and hands the best passages to a human. It cannot cite a passage it was not shown, and guidance, standards and summaries are never presented as binding. (3) Three role agents have disjoint knowledge scopes and receive facts in sequenced chunks, so they act on incomplete, uneven information. (4) The Coordinator picks the most protective proposed action and marks any clinical, data-transfer or public-claim step as needing a human. (5) The audit log is append-only and each record holds the hash of the one before, so an edit, deletion or reordering is detectable; a published head hash also exposes a cut-off tail. The reasoning trace is each agent's stated rationale plus the chunk ids it cited, not hidden model reasoning.

3. Use case requirement

Requirements per Y.3172 node (R1 to R8). They are the testable conditions the prototype enforces, not legal conclusions.

R1 SRC. Inputs are synthetic lab PDFs and wearable exports; a real deployment would also need a consent record and a device-status check before any import.
R2 C. Every import records source, time and lateness; a late result is disclosed to the member, not hidden (scenario S1).
R3 PP. Each role sees only the facts its mandate entitles it to; the Authority gets data-flow and incident descriptions, not clinical content (S1, S2).

R4 M. Coach replies carry no diagnosis, dose or guarantee; emergency wording skips the model and gives the 999 / 998 message; every model call is logged with alias, answering model and prompt hash.
R5 P. A ruling needs strong evidence and may cite only retrieved passages; otherwise abstain. Caveats read from the chunk record (revision date passed, summary only, non-binding) are attached.
R6 D and SINK. Any clinical, data-transfer or public-claim action is marked needs-human; approval stays pending unless a scenario scripts it, and then it is logged as simulated.
R7 MLFO and sandbox. Scenario information is released in sequenced chunks; each decision record holds the trigger, assessments, cited passages, ruling, action and approval state.
R8 Audit. Hash-chained JSONL; the verifier exits non-zero on any broken link; head hashes of the four published runs are recorded.

4. Mapping with ITU-T Y.3172 Readiness 2.0 Report, and domain-specific policies

Table 1. Y.3172 pipeline node, Miqyas component, AI Readiness 2.0 dimension and supporting documents.

Node	Miqyas component (use case)	Readiness 2.0 dimension	Documents in the knowledge base
SRC	Synthetic lab PDFs and wearable exports	Dim 1 Data/model marketplace; Dim 13 Digital infrastructure	Health-ICT Law 2/2019; Data Protection Decree-Law 45/2021 (PDPL, partial); MOHAP Res. 51/2021 (ministry summary); DoH ADHICS v2; TDRA type-approval policy and regulation; TDRA IoT procedures. Pending: Decree-Law 38/2024.
C	Import collector for lab and wearable files	Dim 13 Digital infrastructure; Dim 5 Level of integration of AI in workflows	Law 2/2019 and Cabinet Res. 32/2020; Res. 51/2021 summary; PDPL; DHA health information sharing policy 2024; DoH Health Information Exchange policy 2020; ADHICS v2; TDRA IoT procedures.
PP	Normaliser and de-identifier; scoped views per role	Dim 1 (harmonised representation); Dim 10 AI & Policies	Law 2/2019; Cabinet Res. 32/2020; PDPL; DHA sharing policy; DoH HIE policy; ADHICS v2.
M	Coach model and Adviser model (free-tier gateway, one alias)	Dim 2 Generated content marketplace; Dim 4 Contextualization and regional impact	PDPL; DHA AI in Healthcare policy 2021; DoH AI policy 2018 (v0.9); UAE AI Charter 2024; Dubai AI Ethics 2022. Pending: WHO AI-for-health guidance 2021, Decree-Law 38/2024.
P	Policy node: Policy and Legal Adviser plus output guard	Dim 10 AI & Policies; Dim 7 Strategy alignment; Dim 8 Collaboration with AI	PDPL; DHA and DoH AI policies; DHA telehealth standards v4; DHA and MOHAP advertising rules; AI Charter; National AI Strategy 2031. Pending: Consumer Protection Law 15/2020, Medical Liability Decree-Law 4/2016, WHO guidance.
D	Distributor to member, clinic and authority	Dim 3 Cross-domain correlation analysis; Dim 5 Level of integration	Law 2/2019; Res. 51/2021 summary; PDPL; DHA telehealth policy and standards; DHA sharing; DoH HIE; ADHICS v2; DHA and MOHAP advertising rules; National Media Council advertising guide; MOHAP promotion code 2017.
SINK	Member app, clinic inbox, authority report	Dim 6 Human interface; Dim 8 Collaboration with AI; Dim 11 AI for inclusion (not met, see limits)	As for D, plus the DHA and DoH AI policies. Pending: Law 15/2020, Decree-Law 4/2016.
MLFO, sandbox	Coordinator; replayable scenario runner on synthetic data	Dim 7 Strategy alignment; Dim 10 AI & Policies	ITU-T Y.3172; ITU AI Readiness Report 2.0; UAE AI Charter 2024; National AI Strategy 2031.

Our own mapping, not reviewed by ITU or a lawyer. Dimension numbers and titles are those of the AI Readiness Report 2.0. "Pending" documents could not be fetched by script (portal bot protection) and are not in the knowledge base, so no answer here can cite them.

5. Error scenarios.

Four synthetic scenarios, three sequenced chunks each, were run end to end on 28 Oct 2026 through a model gateway, alias "auto" (free model pool; no Claude model answered). Table 2 shows what each releases and where the controversy sits. Logs: runs/2026-10-28/S1 to S4.

Scenario	Steps released in order	Who knows what	What the agents did, and the controversy
S1 Red-flag lab result	1 Critical potassium flag and a risky question from the member. 2 Emergency wording in chat. 3 The lab import turns out to be 6 hours late.	Coach holds lab and chat. Authority gets only a content-free incident report in step 3. Clinic is never told.	Emergency wording skipped the model and returned the 999 / 998 message; the draft reply said to seek urgent care with no diagnosis or dose. All 3 decisions needs-human. Whether the clinic should be told is left to a human.
S2 Wearable localisation	1 Wearable linked, cloud country unknown. 2 Vendor says Europe; consent text is silent on transfer. 3 Clinic asks for all wearable data.	Authority holds the data-flow and vendor reply; Coach holds the consent text; Clinic sees only its own form.	Asked whether explicit consent is enough, the Adviser cited PDPL Art. 23 and noted that the PDPL steps aside for health data with its own law and that its executive regulations are unconfirmed. It did not settle which law applies (gaps G1, G2). The Authority applied an Abu Dhabi standard to a Dubai-based member, which shows unclear reach.
S3 Clinic record sharing	1 Clinic asks for 12 months of labs. 2 Member moves to Abu Dhabi. 3 Clinic asks for the whole coach chat.	Coach holds the consent scope and mood notes; Clinic holds the request; Authority hears only about routing in step 2.	Scope of consent and which emirate's rules follow the member are the controversy. Two citations were decision ids copied from a routed message, not chunk ids; the check stripped them and lowered confidence.
S4 AI health claim	1 Draft advert promising results. 2 Influencer testimonial. 3 AI-written personalised outcome messages.	Coach holds the draft and influencer facts; Clinic is asked to be named; Authority holds one complaint and no instruction on AI messages.	On the four questions about AI-written personalised health messages the Adviser found only weak evidence and gave no ruling (gap G5). The keyword guard once blocked a note that merely quoted the word "guaranteed" (a false positive, fixed afterwards; the published logs are from before the fix).

Results (one run each, all four chains verify). 12 decisions, all marked needs-human; 42 Adviser questions gave 18 rulings (strong evidence) and 24 abstentions (weak evidence, no ruling attempted); 2 citations stripped; 90 model calls, 0 failed; 479 audit records.

Scenario extension (designed, not run). A judge-style twist for our domain: the regulator finds that the coach uses inferred health conditions to tailor offers. From the knowledge-base contents, the Adviser would be expected to find no rule on AI-personalised health marketing (gap G5) and little on purpose limitation for health data held by a non-facility app (G1), abstain, and route the case to a human with the nearest passages. We present this as the expected behaviour of the design, not as a measured result.

6. Policy gaps and standards gaps derived from the mapping exercise

Table 3. Candidate gaps at domain level (consumer health AI). The second column states what the retrieved UAE text says (chunk ids from docs/POLICY_GAPS_CANDIDATES.md). The third gives a public global example, with its source. None has been checked by a lawyer.

#	Gap, and what the UAE text says	Global example and source	What would settle it
G1	**Which regime governs health data made outside a health service** (self-uploaded labs, wearable streams, coach chats)? The PDPL steps aside for "Personal Health Data that has legislation regulating its protection and processing" (Art. 2(2)(e)); the health-ICT law covers ICT "in health fields". A consumer app that is not a licensed facility sits between them. [UAE-PDPL-2021:0004; UAE-FL2-2019:0005, :0016]	United States, FTC Health Breach Notification Rule, 16 CFR Part 318 (amended 2024, in force 29 Jul 2024): covers vendors of personal health records that are outside HIPAA, and a product with "the technical capacity to draw information from multiple sources" can qualify. It names the app category and gives it a regulator. Washington My Health My Data Act (RCW 19.373; duties from 31 Mar 2024) covers health data held by apps outside HIPAA, including data inferred by algorithms or machine learning. ecfr.gov (16 CFR 318); ftc.gov (26 Apr 2024); app.leg.wa.gov.	Written view from the UAE Data Office and MOHAP, or counsel.

#	Gap, and what the UAE text says	Global example and source	What would settle it
G2	**Does explicit consent legitimise sending health data abroad?** PDPL Art. 23(1)(b) allows transfer with explicit consent. The health-ICT law bars offshore storage or processing unless a health-authority decision defines the case, and the ministry summary of Res. 51/2021 lists cases with no consent case. If both apply, consent alone may not suffice. [UAE-PDPL-2021:0017, :0018; UAE-FL2-2019:0016; MOHAP-MD51-2021:0001; DHA-HIS-2024:0028]	EU, GDPR Art. 49(1)(a) and EDPB Guidelines 2/2018 (25 May 2018): derogations "must be interpreted restrictively" and the GDPR "sets a high threshold" for the consent derogation; exporters should use the standard transfer tools first. edpb.europa.eu; eur-lex.europa.eu (Reg. 2016/679).	Full Arabic text of Res. 51/2021; a ruling on which law prevails.
G3	**Is a consumer wearable a "simple medical device" for the localisation exemption?** The ministry brief names "information related to simple medical devices and tools" as exempt but, in the English summary, gives no definition or threshold. [MOHAP-MD51-2021:0001]	United States, FDA guidance General Wellness: Policy for Low Risk Devices (6 Jan 2026, replacing the 2019 version): published criteria (wellness use, low risk, non-invasive) with worked examples that include wearables. fda.gov/media/90652/download.	Full resolution text; device classification (Decree-Law 38/2024, still pending).
G4	**Overlapping AI-in-health regimes and no single rule owner for a direct-to-consumer AI coach.** Dubai's AI policy (v1, 2021; stated revision date now passed) and Abu Dhabi's (v0.9, 2018) each reach AI developers that use that emirate's population or patient data; the federal AI Charter calls itself "a guiding framework". [DHA-AI-2021:0001; DOH-AI-2018:0001; UAE-AI-CHARTER-2024:0001]	EU, MDCG 2025-6 / AIB 2025-1 (June 2025): the Medical Devices Regulation and the AI Act apply in a "simultaneous and complementary application" to medical devices containing high-risk AI. It covers medical-purpose products only; we found no equivalent for a coach without a medical purpose in the sources checked. health.ec.europa.eu (mdcg_2025-6_en.pdf).	Check for newer DHA and DoH versions; confirm whether a federal AI-in-health instrument exists.
G5	**Advertising rules do not mention AI-generated or personalised health claims.** The advertising texts set prior-approval duties and list prohibited expressions ("guaranteed", "no side effects") for conventional adverts, split over three documents. A query on AI-generated recommendations in health adverts returned only weak evidence (best score 12.2). [NMC-AD-GUIDE:0004, :0005; DHA-MEDAD-2022; MOHAP-HEALTHAD-GUIDE]	US FTC, Operation AI Comply (25 Sep 2024): "there is no AI exemption from the laws on the books"; FTC Health Products Compliance Guidance (Dec 2022): the substantiation standard for health claims is "a rigorous one". UK CAP/ASA (27 Aug 2026): existing rules apply to ads for AI health assistants, and the ASA covers the advertising, not the AI product's own behaviour. None covers a claim the AI generates inside the app at run time (not found in the sources checked). ftc.gov; asa.org.uk.	Current media law and executive regulations; Consumer Protection Law 15/2020 (pending).
G6	**Breach-notification timing is delegated to regulations the knowledge base does not hold.** The PDPL requires notice to the regulator and the data subject but sets the period in its Executive Regulations; whether they have been issued is not confirmed by this project (secondary sources disagree). [UAE-PDPL-2021:0009, :0010]	EU, GDPR Art. 33(1) fixes the period in the statute: "not later than 72 hours after having become aware", with reasons required for delay. US, 16 CFR 318.4: no later than 60 calendar days, FTC notice for 500 or more people at the same time. Both put the number in the instrument itself. eur-lex.europa.eu; ecfr.gov.	Primary text of the Executive Regulations, or a statement that none exist.
G7	**Human review of automated decisions is a right on request with no stated standard.** The PDPL lets a person object to an automated decision and requires the controller to "include the human element" on request, with no time limit, qualification or record-keeping standard; the Dubai AI policy says AI is "supportive technology" supervised by end users, and the AI Charter lists human oversight, but neither sets a procedure. [UAE-PDPL-2021:0013; DHA-AI-2021:0006, :0007; UAE-AI-CHARTER-2024:0002]	EU, GDPR Art. 22(3): at least the right to obtain human intervention, to express a view and to contest; CJEU Case C-634/21 SCHUFA (7 Dec 2023) read "decision" broadly. EU AI Act Art. 14 (human oversight): overseers must be able to recognise automation bias and to disregard, override or reverse the output. eur-lex.europa.eu; ai-act-service-desk.ec.europa.eu.	Executive regulations; any DHA or DoH review-procedure guidance.

#	Gap, and what the UAE text says	Global example and source	What would settle it
G8	**Standards gap (Y.3172).** Y.3172 gives a policy node that applies policies to model output, and an ML sandbox, but no vocabulary for which policies (legal rules, consent state, licensing status) a health deployment must evaluate there, or for recording the legal basis of an automated action. We propose the Adviser as that node and log the cited provision per decision. [ITU-Y3172 (P node, sandbox); ITU-AIREADY-2 Dim 10]	In the public pages we reviewed (EU AI Act Arts. 12 and 19; the public ISO/IEC 42001 and 23894 pages; ISO/IEC 42001 control A.6.2.8 as reproduced by third parties; NIST AI RMF GOVERN) we found logging requirements but no vocabulary for recording the legal basis or rule applied to one automated action. Not read: the paid ISO full texts, AI Act Art. 12(2)(a) to (c), ISO 27001 and 27701 controls.	Review with the ITU mentors (sessions of 31 Oct and 7 Nov).

Limits. One run per scenario; model choice varies per call, so a rerun will differ and no statistics are claimed. Rulings are model-written from retrieved passages and sometimes add inference; the "fit to finding" check is the same lexical ranking, a plausibility check and not proof. Retrieval is lexical (BM25) with 3 documented misses, and about half of on-topic answers are "weak" evidence, which is why abstentions are common. The knowledge base holds 23 of 27 listed sources; the PDPL has 12 of 31 articles; Res. 51/2021 is the ministry summary only; some DHA and DoH documents are past their stated revision dates. All 12 decisions were marked needs-human, so the runs do not exercise a "safe to proceed" path; 2 of 12 approvals were scripted and marked simulated. The knowledge base and agents re-implement the ITU reference design; the ITU reference script was not run. The prototype is English only, so Readiness dimension 11 (inclusion) is not met, and prototype accuracy was not measured. We make no claim that data stays in the UAE. 151 agent-layer tests and 14 knowledge-base tests pass; none of them needs a model or a network.